PRACTITIONER WHITEPAPER

Purdue 2.0:

Extending the Purdue Enterprise Reference Architecture

for Cloud Integration and AI Governance Across Critical Infrastructure OT Sectors

Kevin Schramm, CISM

Cybersecurity Specialist — Energy (LNG / Clean Power) and Healthcare OT

Author: Hacking Your Career Path: The IT to Cybersecurity Transition

July 2026

EXECUTIVE SUMMARY

The Purdue Enterprise Reference Architecture has governed industrial control system security for three decades. Its five-level hierarchy — from field devices through enterprise IT — remains the foundational reference for OT security across energy, manufacturing, oil and gas, water, transportation, and healthcare. But the model was built for a world of air-gapped networks and static device populations. That world no longer exists. Colonial Pipeline entered through a cloud-hosted VPN portal. NotPetya propagated through flat IT/OT networks at Maersk and Merck. WannaCry reached 80 NHS trusts through unsegmented internal networks. Change Healthcare exposed 192.7 million individuals after nine days of undetected lateral movement through a Citrix portal with no multi-factor authentication. The common thread across every major OT-adjacent incident of the last decade is the same: a cloud-hosted or internet-facing interface — existing outside the Purdue hierarchy with no formal zone governance — became the entry point for catastrophic propagation. This whitepaper proposes a formal extension to the Purdue Model: a Level 6 Cloud Tier specification that governs cloud-hosted systems as a formal security zone, a four-class AI governance taxonomy that addresses AI agents as a new category of security principal, and a cross-sector implementation roadmap grounded in empirical incident evidence. This is Purdue 2.0 — built for the environment that actually exists.

Submitted for distribution consideration: E-ISAC / ONG-ISAC member organizations

1. The Architectural Problem No Sector Has Solved

The Purdue Enterprise Reference Architecture was developed at Purdue University in 1992 as a reference model for data flows in computer-integrated manufacturing. Over three decades it became the foundational security framework for every critical infrastructure sector that operates industrial control systems — energy, oil and gas, manufacturing, water and wastewater, transportation, and healthcare. ISA/IEC 62443 is built on it. NIST SP 800-82 references it. Every OT security practitioner in the world learned their craft using its five-level hierarchy as the conceptual map.

That hierarchy assumed two things that are no longer true in any sector: that OT networks would remain physically isolated from enterprise IT, and that the devices populating the lower levels would be static, purpose-built, and locally managed. Both assumptions have been invalidated by the same forces simultaneously — cloud computing, remote access requirements, digital transformation mandates, and the explosion of IP-connected devices at every level of the operational stack.

The SANS 2024 ICS/OT Survey found that only 8.2% of organizations now maintain 100% isolated OT systems. The other 91.8% are operating a Purdue-structured security architecture in an environment the model was not designed for — with no formal framework specification for what lies beyond Level 5.

> **The Shared Architectural Gap Across All OT Sectors**
> *Every critical infrastructure sector using the Purdue Model faces the same unresolved problem: cloud-hosted systems — remote access portals, SaaS historian platforms, AI inference engines, vendor management tools, and MCP servers — interact with OT infrastructure at every level of the Purdue hierarchy but exist in a formal governance vacuum. No Purdue zone specification, no IEC 62443 conduit definition, and no NIST SP 800-82 boundary architecture addresses the interface between on-premises OT networks and cloud infrastructure. This whitepaper proposes to close that gap.*

1.1 The Incident Record Is the Evidence Base

The argument for Purdue extension does not rest on theoretical threat modeling. It rests on the forensic record of the most consequential OT-adjacent incidents of the last decade. Across sectors, the pattern is identical: a Level 6 interface — existing above and outside the Purdue hierarchy with no formal zone governance — became the entry point for propagation that the internal Purdue architecture was powerless to prevent because it had no specification for that boundary.

Incident	Sector	Entry Vector	Architectural Failure	Documented Impact
Colonial Pipeline May 2021	Energy / Pipeline	Compromised VPN credentials on a legacy portal (T1133)	No MFA; no formal Level 6 governance for remote access interface	Largest U.S. fuel pipeline shut down; $4.4M ransom; fuel shortages across Eastern Seaboard
NotPetya June 2017	Cross-sector (Shipping,	EternalBlue/SMBv1 propagation across	Absent Level 3.5 iDMZ; flat network spanning enterprise and OT	Maersk: $250-300M, 10-day rebuild; Merck: $870M;

Incident	Sector	Entry Vector	Architectural Failure	Documented Impact
	Pharma, Logistics)	flat IT/OT networks (T1190)		FedEx/TNT: $300-400M; ~$10B global
WannaCry / NHS May 2017	Healthcare	EternalBlue self-propagation across unsegmented internal networks (T1190)	Flat network; no enforced zone boundaries between clinical levels	80/236 NHS trusts affected; 19,494 appointments cancelled; £5.9M documented loss
Oldsmar Water February 2021	Water / Wastewater	TeamViewer remote access software with shared credentials (T1133)	No Level 6 governance for remote access to Level 1 SCADA; no MFA	Attacker briefly raised sodium hydroxide to 111x safe level; operator caught manually
Change Healthcare February 2024	Healthcare	Citrix portal, stolen credentials, no MFA (T1133)	Level 6 cloud portal with no zone governance; 9-day undetected lateral movement	192.7M individuals; $2.457B documented cost; 94% of U.S. hospitals financially impacted
Ardent Health November 2023	Healthcare	Ransomware propagation across insufficiently segmented clinical network	Flat or minimally segmented network across 30 hospitals, 6 states	30 hospitals affected; ERs on divert; Epic offline; ~$80M estimated impact

Table 1. Cross-Sector OT Incident Record — Level 6 Entry Vectors and Flat-Network Propagation (2017–2024)

The cross-sector pattern is not coincidental. It is architectural. Every incident in Table 1 exploited the same structural gap: a connection point between the organization's internal network and an external or cloud-hosted system that existed outside the Purdue hierarchy's formal governance logic. Colonial Pipeline's VPN portal. Change Healthcare's Citrix interface. Oldsmar's TeamViewer installation. These are all functionally equivalent: Level 6 interfaces with no zone specification, no enforced conduit rules, and no security level assignment under IEC 62443.

Dragos 2024 Natural Experiment — The Segmentation Finding

Dragos's 2025 OT Cybersecurity Year in Review, covering incidents across all critical infrastructure sectors in 2024, provides the strongest available observational evidence: "Organizations that enforced strict network segmentation between IT and OT systems significantly shortened recovery times and avoided paying the ransom. Conversely, organizations that did not employ network segmentation experienced more lengthy recovery times, more involved incident response efforts, and more exposure to data exfiltration." Approximately 70% of all OT-related incidents originated in the IT environment — confirming that the IT/OT boundary is the decisive architectural control point across all sectors. (Dragos, 2025)

2. The Purdue Model Today — What Still Works and What Does Not

Before proposing an extension it is necessary to be precise about what the Purdue Model actually provides in 2026, and where its boundaries of applicability genuinely lie. The field makes two opposing errors: treating the model as fully adequate for modern OT environments, or dismissing it as obsolete. Both are wrong.

2.1 What Still Works

The Purdue Model's philosophical core remains valid and important. Functional isolation reduces attack surface. Controlled inter-zone communication limits lateral movement. Defense-in-depth through hierarchical boundaries creates multiple enforcement opportunities against an adversary who must traverse each boundary to reach their target. These principles are as sound in 2026 as they were in 1992. The NIST NCCoE's own testbed builds — SP 1800-8 for healthcare medical devices, SP 1800-24 for PACS imaging systems, SP 1800-10 for manufacturing ICS — all validate Purdue-style zone segmentation as an effective defensive architecture when properly implemented.

Dragos's natural-experiment finding that segmented organizations avoided ransom payment and shortened recovery confirms the model's operational value in the field. The philosophy works. The model's value as a shared vocabulary — allowing OT engineers, IT security teams, and executives to discuss the same environment using common terminology — is independently valuable and irreplaceable by any currently proposed alternative.

2.2 What No Longer Works

Three specific assumptions embedded in the original model are no longer valid in any critical infrastructure sector:

- The Air-Gap Assumption: The model assumed Levels 0–3 would remain physically isolated from Levels 4–5 and the external internet. With only 8.2% of organizations maintaining full isolation (SANS, 2024), this assumption has been empirically invalidated across the entire ICS/OT industry.
- The Static Device Assumption: The model assumed devices at Levels 0–2 would be purpose-built, fixed-function, and locally managed. IP-connected devices running general-purpose operating systems, managed by cloud-based vendor platforms, and updated through internet-connected patch management systems are now the norm rather than the exception.
- The Five-Level Completeness Assumption: The model assumed that Levels 0 through 5 represented the complete universe of systems relevant to OT security governance. Cloud platforms, SaaS applications, AI inference engines, and vendor remote access portals are now operationally integral to every sector's OT environment — and none of them have a formal place in the model.

The Core Argument in One Sentence

The Purdue Model's philosophy is correct and its five internal levels remain the right organizational structure for on-premises OT security — but it is missing a sixth level that governs the cloud boundary where the most consequential attacks of the last decade have entered.

3. Purdue 2.0 — The Level 6 Cloud Tier Extension

This whitepaper proposes a formal extension to the Purdue Enterprise Reference Architecture: a Level 6 Cloud Tier that governs cloud-hosted systems as a formal security zone with defined conduit specifications, security level requirements, and governance obligations equivalent to the on-premises levels already specified in ISA/IEC 62443.

The Level 6 designation is not arbitrary. It follows the model's existing logic: each level represents a distinct functional layer with distinct security requirements, distinct communication patterns, and distinct trust relationships with adjacent levels. Cloud-hosted systems meet all three criteria. They perform distinct functions (AI inference, historian data aggregation, remote access mediation, vendor management). They have distinct communication patterns (bidirectional API calls, session-based remote access, asynchronous data feeds). And they have a distinct and poorly defined trust relationship with Level 5 enterprise IT and through it with every lower level of the hierarchy.

Level	Name	Cross-Sector Examples	Primary Security Concern	IEC 62443 Zone Status
0	Physical / Field	PLCs, RTUs, sensors, actuators, field instruments, medical devices, turbine controls	Legacy firmware; no authentication; proprietary protocols; physical access	Zone — SL-2 minimum recommended
1	Basic Control	DCS, safety systems, pump/valve controllers, embedded device firmware	Vendor remote access; proprietary protocol exploitation; firmware supply chain	Zone — SL-2 minimum recommended
2	Supervisory Control	HMI workstations, engineering stations, operator consoles, clinical workstations	Ransomware staging area; credential harvesting; direct enterprise access	Zone — SL-2 to SL-3
3	Site / Facility Operations	Historian servers, MES, ERP integration, clinical information systems, SCADA servers	Lateral movement target; Active Directory dependency; high-value data aggregation	Zone — SL-2 to SL-3
3.5	OT / IT DMZ	Data diodes, jump servers, proxy historians, integration engines, API gateways	Single most critical enforcement boundary; bidirectional trust; primary attack pathway	Conduit — explicit allow-list; continuous monitoring
4	Enterprise IT	Corporate IT, ERP, email, HR, finance, Active Directory, patch management	Primary ransomware ingress; credential theft; phishing entry; AD compromise	Zone — SL-1 to SL-2; ZTA identity controls
5	Corporate / Internet Gateway	DMZ, perimeter firewall, internet-facing services, corporate VPN concentrators	Internet-facing attack surface; perimeter breach; supply chain ingress	Zone — SL-1; perimeter hardening

Level	Name	Cross-Sector Examples	Primary Security Concern	IEC 62443 Zone Status
6 (NEW)	Cloud / Extended Tier	Cloud historians, SaaS SCADA, AI inference platforms, vendor remote access portals, MCP servers, OT asset management SaaS	Ungoverned access boundary; no prior Purdue zone spec; supply chain; model poisoning; no MFA (Colonial, Change Healthcare)	PROPOSED: Formal zone — ZTNA enforced; MFA mandatory; conduit specification required for every connection to L4/L5

Table 2. Purdue 2.0 — Complete Zone Map with Level 6 Cloud Tier Extension (Schramm, 2026)

3.1 Level 6 Connection Governance — What Every Cloud Interface Requires

The Level 6 specification is not a single control. It is a governance framework requiring that every connection between cloud-hosted systems and on-premises Purdue levels be treated as a formal conduit under IEC 62443 — with explicit allow-listing, authentication requirements, monitoring obligations, and security level assignment. The following table defines the governance requirements for each primary Level 6 connection type, applicable across sectors:

Connection Type	Sector Examples	On-Premises Equivalent	Minimum Required Controls	Incident Evidence
Cloud remote access / VPN portal	Colonial Pipeline VPN; Change Healthcare Citrix; Oldsmar TeamViewer; vendor OT maintenance portals	L3.5 jump server / PAM gateway	ZTNA (replaces VPN); phishing-resistant MFA mandatory; session recording; time-limited; least-privilege; PAM-governed	Colonial Pipeline ($4.4M ransom); Change Healthcare ($2.457B; 192.7M individuals); Oldsmar (near-miss: sodium hydroxide level)
Cloud historian / SaaS SCADA	OSIsoft PI Cloud, AVEVA System Platform cloud, GE Predix, AspenTech cloud historian	L3 historian server	Data diode or one-way replication where feasible; encrypted transmission; BAA/DPA equivalent for OT data; no direct write-back to L0-L2 without explicit conduit approval	NotPetya: flat historian networks enabled cross-facility propagation at Merck and Maersk
AI inference endpoint	Predictive maintenance AI, anomaly detection platforms, digital twin cloud components, clinical DSS	L3.5 DMZ analytics	Model integrity verification; behavioral baseline monitoring; scoped data access (read-only); output attestation; no autonomous write-back to L0-L2 control systems	IBM (2025): 1-in-5 breaches involve AI/shadow AI; AI breach cost premium $670K
Vendor / OEM remote management	ICS vendor remote maintenance, OEM diagnostic	L3.5 jump server	ZTNA with MFA; vendor-specific PAM accounts (no shared credentials); session recording and	Oldsmar: TeamViewer with shared credentials; CISA ICS-MA series: vendor

Connection Type	Sector Examples	On-Premises Equivalent	Minimum Required Controls	Incident Evidence
	portals, biomedical vendor access, SCADA support		real-time monitoring; time-window restrictions; contractual security obligations	access as documented attack vector across 20+ device advisories
MCP server / agentic AI	AI security operations platforms, autonomous patch management, agentic workflow tools, LLM-integrated SCADA interfaces	No prior Purdue equivalent	Agent registry with provenance verification; permission scoping (no blanket L0-L3 access); NHI lifecycle governance; human-in-loop for any L1/L2 action; behavioral audit trail	Fuller (2026): AI-speed lateral movement compresses attacker dwell time; Secureworks (2023): median dwell now <24 hours

Table 3. Level 6 Cloud Tier — Connection Governance Requirements with Cross-Sector Evidence Basis

4. AI as a Security Principal — The Governance Gap Every Sector Faces

Artificial intelligence introduces a category of architectural challenge that the original Purdue Model has no mechanism to address. The model's governance logic accommodates two security principals: humans and devices. AI systems — particularly agentic AI, autonomous operations platforms, and shadow AI tools used by operational staff — fit neither category. They initiate network sessions autonomously, consume data from multiple Purdue levels simultaneously, execute actions without per-transaction human authorization, and terminate connections on their own schedule.

This is not a future risk. The FDA has authorized over 1,000 AI-enabled devices in healthcare alone. Predictive maintenance AI platforms are deployed across energy and manufacturing OT environments, consuming Level 0 sensor data and returning recommendations that influence Level 1 control decisions. Shadow AI — operational staff using unsanctioned AI tools for shift reporting, anomaly analysis, or equipment diagnostics — creates network connections that cross every Purdue level simultaneously, through pathways architecturally indistinguishable from legitimate operational traffic.

AI Class	Cross-Sector Examples	Purdue Behavior	Primary Security Risk	Required Governance
Class 1 — Embedded OT AI	Turbine control AI, pipeline pressure optimization algorithms, predictive maintenance embedded in PLCs, medical device AI algorithms	Resident at L0–L1; behaves as device component	Adversarial input; model drift; firmware supply chain compromise; vendor update as attack vector	Firmware governance equivalent to device updates; SBOM; adversarial testing; cryptographic model attestation; postmarket monitoring plan
Class 2 — On-Premises Analytics AI	Historian anomaly detection, process optimization AI on L3 servers, SCADA predictive analytics, clinical decision support on-premises	Data consumer at L3/L3.5; recommendation output to operators	Data exfil via inference API; recommendation poisoning; scope creep beyond defined data access	Defined data scope; no autonomous write-back to control systems; output attestation; behavioral baseline monitoring; operator-in-loop requirement
Class 3 — Cloud AI / Digital Twin	Cloud predictive maintenance, remote asset monitoring AI, cloud digital twins, population-level analytics platforms	Operates at Level 6; bidirectional with L3 and below	PHI/OT data exposure; model poisoning; update supply chain; vendor as attack vector	Level 6 governance applies; contractual security equivalent to BAA/DPA; model update governance equivalent to device firmware governance; data sovereignty controls
Class 4 — Agentic / Shadow AI	Unsanctioned AI tools used by operators/technicians, autonomous patch agents, MCP-enabled workflow tools, AI-	Unplaced — bypasses all Purdue levels simultaneously	Layer bypass; data exfiltration; privileged action without human authorization; blast radius amplification at AI speed	Approved tool registry; traffic behavioral analysis at L3.5 DMZ; production write-access prohibition pending security review; NHI lifecycle

AI Class	Cross-Sector Examples	Purdue Behavior	Primary Security Risk	Required Governance
	assisted SCADA interfaces			governance for sanctioned agents

Table 4. Cross-Sector AI Governance Taxonomy — Purdue Placement and Required Controls (Schramm, 2026)

The AI-Speed Attack Problem — Fuller (2026)

"The day-zero normal is not a future state. It is the current operating environment. For a growing class of high-value vulnerabilities, working exploits are available within hours of CVE publication. Your patch cycle takes weeks. Your change approval process takes days. Segmentation is the control that converts 'exploitable in your environment' into 'exploitable only within the zone where initial access landed.' Without it, AI-assisted lateral movement operates faster than any human-led detection and response process can interrupt." — Fuller, R. (2026). The day-zero normal. Vulnerability Management Research Group.

5. The Zero Trust Integration — Purdue Topology, ZTA Enforcement

Zero Trust Architecture and the Purdue Model are frequently positioned as competing frameworks. They are not. They operate at different layers of abstraction and are functionally complementary when properly integrated. The Purdue Model defines where security boundaries exist — the topology. Zero Trust defines how those boundaries are enforced — the verification logic at each crossing.

The integration is not uniform across Purdue levels, however. ZTA's continuous verification requirement introduces latency that varies in clinical and operational consequence depending on the level at which it is applied. The correct integration model is differentiated by level:

Purdue Level	ZTA Application	Enforcement Mechanism	Operational Constraint
L0–L1 (Field / Control)	ZTA principles via architectural isolation — not continuous packet verification	Zone boundary enforcement; passive behavioral monitoring via digital twin or network TAP; no direct enterprise-to-device routing paths	Latency constraint: control loop timing in milliseconds is incompatible with per-packet verification overhead. Architecture replaces verification.
L2 (Supervisory)	ZTA for all remote and cross-zone access; MFA for authentication	PAM-governed access; phishing-resistant MFA; application allow-listing; EDR on all workstations	Manageable latency; this is the highest-value ransomware staging layer — ZTA is essential and feasible here
L3–L3.5 (Operations / DMZ)	Full ZTA verification at every boundary crossing	Explicit allow-list conduits only; continuous session monitoring; CASB for cloud traffic; API gateway for all L6 connections	This is the decisive enforcement boundary — Dragos (2025) confirms 70% of OT incidents originate from IT, making DMZ enforcement the single highest-leverage control
L4–L5 (Enterprise IT / Gateway)	Full ZTA — NIST SP 800-207 implementation	FIDO2 / FIDO passkey MFA; identity threat detection and response (ITDR); microsegmentation; phishing-resistant email gateway; privileged access workstations	Primary ransomware entry layer across all sectors — full ZTA is both necessary and feasible
L6 (Cloud)	ZTA via ZTNA replacing all VPN; cloud-native identity controls	ZTNA with continuous session verification; CASB; API gateway; NHI governance for AI agents and service accounts; MFA mandatory for all human access	Colonial Pipeline and Change Healthcare: absent MFA at L6 interface was the direct enabler of both attacks. This is non-negotiable.

Table 5. Zero Trust Integration Across Purdue 2.0 Levels — Differentiated by Operational Constraint

6. Implementation Roadmap — Triage by Consequence

Effective implementation of Purdue 2.0 requires triage-based sequencing: protect first what, if compromised, produces the greatest operational, safety, or national security consequence. The roadmap is deliberately sector-neutral — the phase structure applies to energy, oil and gas, manufacturing, water, and healthcare alike, with sector-specific examples provided at each phase.

Phase	Timeline	Priority Target	Key Activities	Evidence-Anchored Benchmark
Phase 1 Discovery	0–12 weeks	All network layers including Level 6 cloud interfaces	Passive OT asset discovery (no active scanning at L0-L1); Level 6 cloud interface inventory — every cloud connection, vendor portal, remote access tool, and AI platform; clinical or operational communication flow documentation; legacy device CVE baseline	Asset inventory >95% complete; all Level 6 interfaces mapped; Colonial Pipeline-class VPN/portal interfaces identified and flagged for MFA enforcement
Phase 2 Level 6 Hardening	12–24 weeks	All cloud and remote access interfaces	ZTNA deployment replacing all VPN (Colonial Pipeline lesson); MFA enforcement on every Level 6 interface (Change Healthcare lesson); vendor access PAM implementation; Level 6 cloud inventory governance framework; shadow AI detection at DMZ	Zero ungoverned remote access interfaces; MFA on all L6 human access; vendor session recording operational; shadow AI baseline established
Phase 3 L3.5 DMZ Enforcement	24–52 weeks	IT/OT boundary — the decisive control point	Explicit allow-list conduit rules at DMZ (Dragos: 70% of OT incidents originate from IT); Active Directory isolation from OT domain (UHS/NotPetya lesson); AI governance taxonomy applied to all AI platforms; CASB for cloud traffic; data diodes where unidirectional flow is feasible	No implicit trust at IT/OT boundary; all conduits explicitly specified; AD isolation complete; AI taxonomy applied to all platforms
Phase 4 L0-L2 Zone Isolation	52–104 weeks	Field device and control networks	Zone boundaries enforced per NIST SP 1800-8/1800-10 methodology; passive behavioral monitoring (digital twin or network TAP — no active scanning); SBOM-based device procurement; vendor remote access to L0-L1 via PAM only; legacy device compensating controls documented	L0-L1 network isolated from enterprise AD; all vendor L0-L1 access via PAM; digital twin or behavioral monitoring operational; SBOM program initiated for new device procurement
Phase 5 Strategic Completion	104–156 weeks	Full Purdue 2.0 + ZTA integration	Full ISA/IEC 62443 security level assignment across all zones; ZTA identity	Full Purdue 2.0 architecture operational; Dragos-benchmarked:

Phase	Timeline	Priority Target	Key Activities	Evidence-Anchored Benchmark
			verification at DMZ per Cloud Security Alliance (2025) guidance; Standing Authority Matrix for AI-speed pre-authorized containment responses; quarterly ATT&CK-aligned tabletop exercises with operational staff participation	segmented recovery time <72 hours for critical systems; dwell time detection target <15 minutes at identity layer

Table 6. Purdue 2.0 Implementation Roadmap — Cross-Sector Triage-Based Sequencing

The Standing Authority Matrix — Pre-Authorization for AI-Speed Response

When an AI-assisted attack progresses from initial access to ransomware deployment in under 24 hours (Secureworks, 2023), a change approval process requiring committee review is a vulnerability rather than a governance control. A Standing Authority Matrix pre-authorizes specific, scoped, reversible containment actions executable at machine speed — blocking an IP at the perimeter, isolating a VLAN segment, terminating a vendor session — without requiring director-level approval at 3 a.m. Critical constraint for energy and OT environments: any automated containment action affecting L0-L2 must be pre-validated against operational safety requirements. An isolation action that interrupts a turbine control loop or a pipeline pressure management system is an operational safety incident, not a containment success. (Fuller, 2026)

7. Sector-Specific Implications

While the Purdue 2.0 framework is designed as a universal extension applicable across all critical infrastructure OT sectors, the operational and safety implications of implementation differ by sector. The following provides sector-specific context for the primary ISAC audiences.

7.1 Energy — Electric Grid (E-ISAC Members)

The electric grid presents the most acute national security dimension of the Purdue 2.0 problem. Substation automation systems, energy management systems, and advanced metering infrastructure all operate within Purdue-structured environments increasingly connected to cloud-based grid management platforms, demand response aggregators, and AI-driven load forecasting systems. NERC CIP standards provide a regulatory framework that partially maps to Purdue zone concepts, but NERC CIP does not formally address cloud-hosted Electronic Security Perimeter (ESP) boundaries — exactly the Level 6 gap this framework proposes to close.

- Primary Level 6 exposure: Cloud-hosted SCADA platforms, demand response aggregator APIs, EMS cloud analytics, and DERMS (Distributed Energy Resource Management Systems) connecting to generation and distribution assets
- Colonial Pipeline intersection: While pipeline rather than electric, the ZTNA/MFA lesson from Colonial Pipeline's VPN compromise applies directly to any cloud-hosted remote access interface to grid OT systems
- AI governance priority: Class 2 and Class 3 AI — on-premises and cloud-based load forecasting, fault detection, and grid stability algorithms — require explicit Purdue placement and governance before autonomous grid action is permitted

7.2 Oil and Natural Gas (ONG-ISAC Members)

Oil and gas environments present the longest Purdue hierarchy in any sector — from wellhead sensors and pipeline RTUs through gathering and processing systems to refinery control networks and terminal management systems, often spanning multiple geographic facilities connected through wide-area SCADA networks. Cloud connectivity has penetrated every level of this hierarchy through production optimization AI, remote monitoring platforms, predictive maintenance systems, and pipeline integrity management tools.

- Primary Level 6 exposure: Cloud-based production optimization AI (Class 3), vendor remote access to wellhead RTUs (Colonial-class vulnerability), cloud pipeline integrity management platforms, and offshore facility remote monitoring systems
- Sector-specific constraint: Pipeline control systems have safety-integrity-level (SIL) requirements that interact with cybersecurity controls — any containment action affecting pipeline pressure management, emergency shutdown systems, or safety instrumented systems requires safety engineering validation before pre-authorization in a Standing Authority Matrix
- Cross-facility propagation risk: Multi-facility ONG environments with shared Active Directory or flat WAN connectivity face the same NotPetya-class propagation risk documented at

Merck and Maersk — where a single compromise propagated across geographically distributed facilities within hours

7.3 Healthcare (H-ISAC / HPH Sector)

Healthcare represents the sector where the patient safety consequence of Purdue architecture failures is most directly quantifiable. Neprash et al. (JAMA Health Forum, 2022) documented a 33% relative increase in in-hospital Medicare mortality at hospitals experiencing ransomware attacks — establishing a peer-reviewed causal chain from network architecture to patient outcome. Dameff et al. (JAMA Network Open, 2023) documented stroke care metric degradation at neighboring unaffected hospitals during a month-long ransomware attack, demonstrating that the patient safety impact propagates beyond the attacked organization.

- Primary Level 6 exposure: SaaS EHR platforms, cloud medical imaging archives, clinical AI inference engines, vendor biomedical device management portals, and telehealth infrastructure
- Unique constraint: Medical devices at L0-L1 carry FDA clearance tied to specific software versions, meaning security patching requires manufacturer authorization and potentially FDA re-clearance — making network segmentation the primary compensating control for legacy devices that cannot be directly hardened
- AI governance priority: FDA-authorized AI-enabled medical devices (Class 1) require the same SBOM and firmware governance as traditional medical devices, plus adversarial input testing specific to the AI model

8. Immediate Actions — What to Do This Week

The Purdue 2.0 framework is a strategic architecture. But the Level 6 gap is an operational risk that exists today, in your environment, in every organization represented in the E-ISAC and ONG-ISAC member community. The following five actions address the highest-consequence exposures identified across the incident record, with no prerequisite program build required.

Action	What to Do	Why It Cannot Wait	Effort
1. Audit every Level 6 remote access interface for MFA	Inventory every VPN concentrator, remote desktop gateway, vendor portal, cloud management console, and ZTNA endpoint that provides access to OT networks. Verify MFA enforcement on every one.	Colonial Pipeline: VPN without MFA. Change Healthcare: Citrix portal without MFA. These are not edge cases — they are the documented entry vector for the two most consequential OT-adjacent attacks of the last five years.	48 hours
2. Map your Active Directory trust paths to OT systems	Identify every OT system that authenticates against enterprise Active Directory. Document which systems a compromised AD administrator account could reach directly.	Universal Health Services: Ryuk reached all ~400 care sites via AD. NotPetya propagated through shared AD infrastructure at Maersk and Merck. AD is the single most exploited trust path from enterprise IT to OT.	1–2 weeks
3. Inventory all Level 6 cloud connections to OT	List every cloud platform that sends data to or receives data from OT systems — historians, AI platforms, vendor portals, SaaS SCADA, digital twins. For each, document: what data flows, in which direction, with what authentication, monitored by whom.	You cannot govern what you have not inventoried. Most organizations have 3–5x more Level 6 connections than they believe they do, accumulated through digital transformation and vendor onboarding without formal security review.	2–4 weeks
4. Deploy shadow AI detection at the DMZ	Implement traffic behavioral analysis at the Level 3.5 DMZ to baseline and detect AI-characteristic communication patterns — large language model API endpoints, generative AI services, unapproved ML platforms. Establish what sanctioned AI traffic looks like so you can identify what is not sanctioned.	IBM (2025): 1 in 5 breaches now involves shadow AI. Operational staff across all sectors are using unsanctioned AI tools. Shadow AI creates Purdue level bypass that no existing segmentation control is positioned to detect.	2–6 weeks
5. Draft a Standing Authority Matrix	Define, document, and get GC and CIO/COO signatures on a pre-authorized containment action list: specific, scoped, reversible actions your	Secureworks (2023): median dwell time now <24 hours; 10% of cases ≤5 hours. Human approval chains that take hours are structurally unable to interrupt AI-speed attack progression. Pre-authorization is	2–4 weeks with legal/leadership

Action	What to Do	Why It Cannot Wait	Effort
	SOC can execute at machine speed without director-level approval. Validate every L0-L1 action against safety engineering before inclusion.	the only viable response architecture.	

Table 7. Five Immediate Actions — Level 6 Exposure Reduction Without Program Prerequisites

9. Conclusion — The Architecture of the Environment That Actually Exists

The Purdue Enterprise Reference Architecture has served critical infrastructure security for thirty years because its foundational insight is correct: systems with different security requirements and operational functions should be separated, communication across those separations should be deliberate and controlled, and a compromise at one level should not automatically propagate to all others.

Colonial Pipeline demonstrated what happens when a Level 6 remote access interface has no zone governance and no MFA. NotPetya demonstrated what happens when the Level 3.5 DMZ does not exist or is not enforced across a multi-facility OT environment. Change Healthcare demonstrated what nine days of undetected lateral movement through an ungoverned cloud interface produces. Dragos demonstrated that organizations with enforced segmentation avoided these outcomes — shortened recovery, avoided ransom, contained propagation.

The evidence is not ambiguous. The architecture of the environment that actually exists in 2026 — where cloud platforms host critical operational systems, where AI agents act as autonomous security principals, where vendor remote access tools connect directly to Level 0 field devices, and where the attacker's operational loop now runs in hours rather than weeks — requires a Purdue Model with a formally specified Level 6.

That is what this whitepaper proposes. Not a replacement for the Purdue Model. An extension of it — honoring the thirty years of proven security architecture it represents, while formally addressing the boundary that thirty years of incident evidence has identified as the decisive point of failure.

Build the zones. Enforce the DMZ. Govern the cloud boundary as Level 6. Classify and control the AI. Pre-authorize the response. The architecture is here. The evidence is clear. The implementation is the work that remains.

References

Abouk, R., & Powell, D. (2024). Ransomware attacks, ED visits and inpatient admissions in targeted and nearby hospitals. *JAMA, 331*(24), 2129–2131. https://doi.org/10.1001/jama.2024.7752

CISA, FBI, & HHS. (2020, October 28). *Alert AA20-302A: Ransomware activity targeting the healthcare and public health sector*. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-302a

CISA. (2021, May). *Alert AA21-131A: DarkSide ransomware — best practices for preventing business disruption from ransomware attacks* [Colonial Pipeline]. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a

CISA. (2023, December). *Healthcare and public health sector: Cybersecurity mitigation guide*. Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/sites/default/files/2023-12/HPH-Sector-Mitigation-Guide-TLP-CLEAR_508c.pdf

Cloud Security Alliance. (2025). *Zero trust for operational technology environments: Implementation guidance for critical infrastructure*. https://cloudsecurityalliance.org/artifacts/zero-trust-for-ot-environments/

CommonSpirit Health. (2023). *Form 10-Q: Second quarter fiscal year 2023 — cyberattack financial impact disclosure*. U.S. Securities and Exchange Commission. https://www.sec.gov/cgi-bin/browse-edgar?action=getcompany&CIK=0001851538&type=10-Q

Control Engineering. (2022, October). Throwback attack: How NotPetya ransomware took down Maersk. *Control Engineering*. https://www.controleng.com/throwback-attack-how-notpetya-accidentally-took-down-global-shipping-giant-maersk/

Dameff, C., Tully, J., Chan, T. C., Castillo, E. M., Savage, S., Maysent, P., Hemmen, T. M., Clay, B. J., & Longhurst, C. A. (2023). Ransomware attack associated with disruptions at adjacent emergency departments in the US. *JAMA Network Open, 6*(5), e2312270. https://doi.org/10.1001/jamanetworkopen.2023.12270

Dragos. (2024). *OT cybersecurity year in review: 2023*. Dragos, Inc. https://www.dragos.com/year-in-review/

Dragos. (2025). *OT cybersecurity year in review: 2024*. Dragos, Inc. https://www.dragos.com/year-in-review/

Forescout Vedere Labs. (2022). *R4IoT: From IoT to IT and OT — a proof of concept for enterprise IoT attack escalation*. Forescout Technologies. https://www.forescout.com/research-labs/r4iot/

Forescout Vedere Labs. (2024, October). *Connected medical device risk analysis: 2024 healthcare IoMT security report*. Forescout Technologies. https://www.forescout.com/research-labs/

Fuller, R. (2026, April). *The day-zero normal: A practical reprioritization guide for CISOs* (CISO field brief). Vulnerability Management Research Group. https://init6.com/papers/Day-Zero-Normal-CISO-Brief.pdf

Ghafur, S., Kristensen, S., Honeyford, K., Martin, G., Darzi, A., & Aylin, P. (2019). A retrospective impact analysis of the WannaCry cyberattack on the NHS. *npj Digital Medicine, 2*, Article 98. https://doi.org/10.1038/s41746-019-0161-6

IBM Security. (2025). *Cost of a data breach report 2025*. IBM Corporation. https://www.ibm.com/reports/data-breach

ISA/IEC 62443. (2023). *Security for industrial automation and control systems*. International Society of Automation / International Electrotechnical Commission.

MITRE Corporation. (2024). *MITRE ATT&CK for enterprise and ICS (v14)*. https://attack.mitre.org

National Audit Office. (2017, October 27). *Investigation: WannaCry cyber attack and the NHS*. UK National Audit Office. https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/

Neprash, H. T., McGlave, C. C., Cross, D. A., Virnig, B. A., Puskarich, M. A., Huling, J. D., Rozenshtein, A. Z., & Nikpay, S. S. (2022). Trends in ransomware attacks on US hospitals, clinics, and other health care

delivery organizations, 2016–2021. *JAMA Health Forum, 3*(12), e224873. https://doi.org/10.1001/jamahealthforum.2022.4873

NHS England. (2018, February). *Lessons learned review of the WannaCry ransomware cyber attack*. https://www.england.nhs.uk/wp-content/uploads/2018/02/lessons-learned-review-wannacry-ransomware-cyber-attack-cio-review.pdf

NIST National Cybersecurity Center of Excellence. (2018). *Securing wireless infusion pumps in healthcare delivery organizations* (NIST SP 1800-8). National Institute of Standards and Technology. https://www.nccoe.nist.gov/publication/1800-8/

NIST National Cybersecurity Center of Excellence. (2020). *Securing picture archiving and communication systems (PACS): Cybersecurity for the healthcare sector* (NIST SP 1800-24). National Institute of Standards and Technology. https://www.nccoe.nist.gov/publication/1800-24/

National Institute of Standards and Technology. (2023). *Guide to operational technology (OT) security* (NIST SP 800-82 Rev. 3). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-82r3

Proofpoint & Ponemon Institute. (2024). *Cyber insecurity in healthcare 2024: The cost and impact on patient safety and care*. Proofpoint, Inc. https://www.proofpoint.com/us/resources/threat-reports/ponemon-cyber-insecurity-healthcare

SANS Institute. (2024). *ICS/OT cybersecurity survey 2024*. SANS Institute Research Publication.

Schramm, K. (2026). *Enhancing healthcare ransomware resilience through segmented cyber-physical architecture*. Unpublished research manuscript [under review].

Secureworks. (2023). *State of the threat: A year in review*. Secureworks CTU. https://www.secureworks.com/resources/rp-state-of-the-threat-2023

Sophos. (2024). *State of ransomware in healthcare 2024*. Sophos Ltd. https://www.sophos.com/en-us/content/state-of-ransomware

UnitedHealth Group. (2024a). *Form 10-Q: Third quarter 2024 — Change Healthcare cyberattack impact disclosure*. U.S. Securities and Exchange Commission. https://www.sec.gov/cgi-bin/browse-edgar?action=getcompany&CIK=UNH&type=10-Q

Universal Health Services. (2020). *Form 8-K: Ransomware attack disclosure*. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/0000352915/000156459020044863/uhs-ex991_6.htm

Williams, T. J. (1994). The Purdue enterprise reference architecture. *Computers in Industry, 24*(2–3), 141–158. https://doi.org/10.1016/0166-3615(94)90017-5

Witty, A. (2024b, May 1). *Hacking America's health care: Assessing the Change Healthcare cyber attack and what's next* [Testimony before the U.S. Senate Committee on Finance]. U.S. Senate Committee on Finance. https://www.finance.senate.gov/download/0501-witty-testimony

About the Author

Kevin Schramm, CISM

Kevin Schramm is a cybersecurity specialist with over two decades of experience in IT and operational technology security, working across energy (LNG and clean power) and healthcare environments. He holds the Certified Information Security Manager (CISM) designation alongside an extensive credential portfolio spanning CompTIA, EC-Council, ISC2, and other industry bodies. His work focuses on OT/ICS security, critical infrastructure protection, and the application of security architecture frameworks to environments where availability failures have direct safety consequences.

He is the author of Hacking Your Career Path: The IT to Cybersecurity Transition and maintains the Unofficial Blue Team Guide to the Galaxy at dadsmancave.wordpress.com. His research on healthcare OT ransomware resilience and Purdue Model adaptation is under review for journal publication.

Blog: dadsmancave.wordpress.com